Coincheck NEM Theft, January 2018

Executive Summary

Prepared by: Kshitij Randhire

Project: Cryptocurrency Exchange Hack Investigation (independent research project)

What happened

Early on 26 January 2018, about 523 million NEM (XEM) coins were taken from Coincheck, one of Japan's biggest crypto exchanges. Reuters put the value at roughly 58 billion yen, or $532.6 million, which makes it one of the largest crypto thefts on record. Coincheck noticed the loss at 11:25 that morning, according to a published case study.

I traced the money on the NEM blockchain myself. The first coins left Coincheck's wallet at 00:02 Japan time, as a small 10 XEM test transfer, followed by much larger ones. Between 02:57 and 03:30 the thief split 523 million XEM across eight new addresses. That 02:57 is the start time Coincheck gave, so I think the company was describing the moment the money began to be spread out, not the first transfer. That is my reading of the timing. I did not find a Coincheck statement confirming it in the sources I collected.

How much was lost

The blockchain shows 526,300,010 XEM leaving Coincheck's wallet in 11 transfers. Coincheck's own figure was about 523 million. The difference is exactly the last three transfers (3.3 million XEM) plus the 10 XEM test transfer, so Coincheck's figure matches the first eight transfers only. All eleven transfers were completed before Coincheck noticed the loss, and I did not find an explanation from the company in the sources I collected.

Why it was possible

The XEM sat in a hot wallet, which is a wallet connected to the internet, and moving it took only one key. All 11 transfers were ordinary transfers signed by that one key, with no second approval. Coincheck's president cited technical difficulties and a shortage of staff (Reuters). The theft ran for hours before anyone noticed, which points to weak monitoring, although public sources do not say whether any alerting existed.

Impact

About 260,000 customers were affected. Coincheck froze deposits and withdrawals for everything except bitcoin and promised to repay customers from its own money, more than 46 billion yen and close to 90% of the loss (BBC). Japan's Financial Services Agency issued a business improvement order, which Deputy Prime Minister Taro Aso discussed at a press conference on 30 January. I found nothing public on whether customers' personal data was exposed, so I have left that as unknown.

What I could not find out

How the attacker got in, who they were, and where the money went after the eight new addresses. One published case study says a company computer was infected with malware, but I could not trace that to a primary source, so I treat it as reported, not confirmed. No internal Coincheck logs, malware samples or disk images are public. This work is a reconstruction from public statements and blockchain records, not a full forensic examination.

Lessons

- Keep most customer funds offline and only a small working balance online.
- Require more than one approval for any large transfer.
- Alert on unusual outflows within minutes, and practise the response. Here, the first 100 million XEM transfer went out about 11 hours before detection.